

HTB ACADEMY

Security Monitoring & SIEM Fundamentals

HTB Academy · Module 211 · SOC Blue Team Track · Walkthrough

A complete, illustrated walkthrough of SIEM fundamentals, the Elastic Stack, SOC roles, MITRE ATT&CK mapping, KQL query writing, and Kibana dashboard triage — written so any reader, technical or not, can follow the reasoning end to end.

Platform	HackTheBox Academy
Module	Security Monitoring & SIEM Fundamentals (#211)
Completion	100% — all sections and questions complete
Analyst	Chayan Panchal · @tron874
Core Skills	KQL, Kibana, Elastic Stack, SIEM triage, MITRE ATT&CK, SOC operations

How to read this document — each numbered section below mirrors a stage of the module. Diagrams show how data or a decision moves step by step; tables capture exact settings and queries used inside Kibana so the walkthrough can be reproduced.

1 What Is a SIEM?

A Security Information and Event Management (SIEM) platform collects logs from across an entire IT environment, normalises them into a common format, correlates events across sources, and raises alerts when suspicious patterns appear. It is the central nervous system of a SOC — every alert, investigation, and escalation decision flows through one.

SIEM Data Flow — How Logs Travel Through a SIEM

1. DATA INGESTION

Logs collected from: firewalls, endpoints, servers, IDS/IPS, applications, databases, cloud platforms

2. NORMALISATION & AGGREGATION

Raw logs converted to a common format (ECS)
Duplicate/related events grouped together

3. CORRELATION & DETECTION

Rules applied: "if X events in Y minutes -> alert"
Threat intel feeds checked against indicators

4. ALERTING & RESPONSE

SOC analyst notified -> triage -> investigate -> respond

SIEM vs. other security tools

Tool	What it does	How a SIEM differs
IDS / IPS	Detects or blocks known attack signatures on network traffic	SIEM ingests IDS/IPS logs and correlates them with everything else
Firewall	Filters network traffic by rule	SIEM aggregates firewall logs to find patterns across time
EDR	Monitors endpoint processes, files, memory	SIEM centralises EDR alerts alongside all other data sources
SIEM	Correlates all of the above into one detection layer	Single pane of glass for the entire environment

SIEM & SOC evolution

Generation	Name	Focus
1st	SIM	Log collection, long-term storage, reporting
2nd	SEM	Real-time event correlation, alerting from IDS/AV/FW
3rd	SIEM	Combined SIM + SEM — unified threat detection platform
SOC 1.0	Network-centric	Perimeter focus, siloed tools, uncorrelated alerts
SOC 2.0	Intelligence-driven	Threat intel, anomaly detection, layer-7 analysis, proactive
Cognitive SOC	AI-augmented	Learning systems, behavioural analysis, automation

2 The Elastic Stack as a SIEM

The Elastic Stack (formerly ELK) is the most widely used open-source SIEM platform. Four components work together to ingest, store, search, and visualise security data.



Lightweight variant (small environments): Beats ship straight to Elasticsearch, skipping Logstash. **High-volume variant**: a buffer (Kafka / Redis / RabbitMQ) sits between Beats and Logstash to absorb spikes.

Elastic Common Schema (ECS) — the field names used in every KQL query

ECS Field	Meaning	Vendor-specific equivalent
event.code	Event identifier (e.g. 4625)	winlog.event_id (Winlogbeat)
user.name	Username involved in the event	winlog.event_data.TargetUserName
host.hostname	Machine name	winlog.computer_name
@timestamp	Event timestamp from the source	different from event.created
event.action	Action that occurred	winlog.task
related.ip	IP addresses involved	winlog.event_data.IpAddress

Rule: always prefer ECS fields in KQL. Use the `.` keyword suffix for aggregations (Rows/Columns in Kibana Lens visualisations).

3 SOC Roles, Tiers & MITRE ATT&CK

SOC analyst tiers

Tier	Role	Primary responsibilities
Tier 1	First Responder	Monitor alerts, initial triage, escalate to Tier 2. Speed is key.
Tier 2	Investigator	Deep-dive analysis, identify patterns, tune detection rules, assist IR.
Tier 3	Expert / Threat Hunter	Complex incidents, proactive threat hunting, advanced detections.
Detection Eng.	Rule Builder	Write and maintain SIEM detection rules, IDS signatures, EDR policies.
Incident Resp.	IR Lead	Contain and eradicate active incidents, forensics, recovery.
Threat Intel	Intel Provider	Gather and analyse threat intel, feed IOCs into the SIEM.

MITRE ATT&CK vocabulary

Term	Definition	Example
Tactic	The adversary's goal — the “why”	TA0002 — Execution
Technique	How the goal is achieved — the “what”	T1127 — Trusted Developer Utilities Proxy Execution
Sub-technique	A specific variation of a technique	T1127.001 — MSBuild
TTP	Tactics, Techniques & Procedures combined	Full picture of attacker behaviour

Applied example from the module — MSBuild abuse

MITRE ATT&CK Mapping	
Detection	MSBuild started by an Office application
Tactic	TA0005 Defense Evasion + TA0002 Execution
Technique	T1127 Trusted Developer Utilities Proxy Execution
Sub-tech	T1127.001 MSBuild
Severity	HIGH — LoLBin abuse is rarely legitimate
Detection	MSBuild making outbound network connections
Tactic	TA0002 Execution
Severity	MEDIUM — could be legitimate update traffic

4 KQL — Kibana Query Language

KQL is the query language used in Kibana's Discover tab and in visualization filters. It is designed to be readable at a glance.

Syntax	Purpose	Example
field:value	Exact field match	event.code:4625
"text"	Free-text search, all fields	"svc-sql1"
AND	Both conditions true	event.code:4625 AND user.name:admin
OR	Either condition true	event.code:4732 OR event.code:4733
NOT	Exclude matches	NOT user.name: *\$
field: val*	Wildcard, starts with	user.name: admin*
field:>= val	Comparison	@timestamp >= "2023-03-03T00:00:00.000Z"
()	Group expressions	(event.code:4625 OR 4624) AND user.name:admin

All KQL queries written during the module

```
KQL Queries

# Failed login attempts
event.code:4625

# Failed logins on disabled accounts
event.code:4625 AND winlog.event_data.SubStatus:0xC0000072

# Failed logins, disabled accounts, 3-6 Mar 2023
event.code:4625 AND winlog.event_data.SubStatus:0xC0000072
AND @timestamp >= "2023-03-03T00:00:00.000Z"
AND @timestamp <= "2023-03-06T23:59:59.999Z"

# Failed logins, admin usernames only (wildcard)
event.code:4625 AND user.name: admin*

# Exclude computer accounts, Security channel only
NOT user.name: *$ AND winlog.channel.keyword: Security

# Service-account RDP logons only
user.name: svc-*
```

Key rule: use `field.keyword` in Kibana Lens Rows/Columns for aggregations; use the plain `field` in KQL filter queries.

5 Windows Security Event IDs

The Windows Security event IDs used throughout the module — every SOC analyst working a Windows environment needs these memorised.

Event ID	Description	SOC relevance
4624	An account was successfully logged on	Monitor service-account RDP, admin logons outside PAW
4625	An account failed to log on	Brute force, disabled accounts, admin targeting
4648	Logon using explicit credentials	Pass-the-hash, lateral movement indicator
4672	Special privileges assigned to new logon	Admin-level privilege use — monitor closely
4720	A user account was created	Detect unauthorised account creation
4728	Member added to global security group	Privilege escalation
4732	Member added to local security group	Local admin group changes — key detection
4733	Member removed from local security group	Account tampering
4740	A user account was locked out	Brute-force result
4756	Member added to universal security group	Domain-level privilege escalation

Event 4625 — SubStatus codes (login-failure reasons)

SubStatus	Meaning	Detection value
0xC0000072	Account is currently disabled	High — disabled-account auth attempt, investigate
0xC000006A	Wrong password provided	Medium — track frequency for brute force
0xC0000064	Username does not exist	Medium — username-enumeration indicator
0xC0000234	Account is currently locked out	Medium — result of brute force
0xC0000193	Account has expired	Low — usually legitimate
0xC0000071	Password has expired	Low — usually legitimate

6 Kibana Dashboards — Build Guide

Four detection dashboards were built from scratch in Kibana during the module. Each card below is the exact configuration used.

VIZ 1 — Failed Logon Attempts (All Users)

Index pattern	windows*
Filter	event.code: 4625
Type	Table (Lens)
Rows	user.name.keyword · host.hostname.keyword · winlog.logon.type.keyword
Metric	Count of records
Extra filters	NOT user.name:*\$ AND winlog.channel.keyword:Security; exclude DESKTOP-DPOESND, WIN-OK9BH1BCKSD
Finding	sql-svc1 showed failed logins — Consult IT Operations

VIZ 2 — Failed Logon Attempts (Disabled Users)

Index pattern	windows*
Filter	event.code: 4625 AND winlog.event_data.SubStatus: 0xC0000072
Type	Table (Lens)
Rows	user.name.keyword · host.hostname.keyword
Metric	Count of records
Finding	User “anni” attempted login on a disabled account — Escalate

VIZ 3 — Successful RDP Logon (Service Accounts)

Index pattern	windows*
Filter	event.code: 4624 AND winlog.logon.type: RemoteInteractive
Type	Table (Lens)
Rows	user.name.keyword · host.hostname.keyword · related.ip.keyword
Extra filter	user.name: svc-*
Finding	svc-sql1 RDP'd from 192.168.28.130 to PKI — Escalate

VIZ 4 — Group Membership Changes (Administrators)

Index pattern	windows*
Filter	(event.code: 4732 OR 4733) AND group.name: administrators
Type	Table (Lens)
Rows	user.name.keyword · winlog.event_data.MemberSid.keyword · group.name.keyword · event.action.keyword
Time range	Absolute — 5 Mar 2023 to present
Finding	Unknown SID added to Administrators on 2023-03-05 — Consult IT Ops

7 Alert Triage & Skills Assessment

Alert triage evaluates a security alert to decide the appropriate response. Three outcomes are possible:



Skills assessment — full SOC dashboard review

Environment context: cloud-only org, 4 IT admins, PAW policy enforced, svc - prefix for service accounts, root SSH disabled.

Failed logon attempts — all users

sql-svc1 shows unusual failed logins — not typical for a service account

CONSULT IT OPS

Failed logon attempts — disabled user

User "anni" attempted auth on a disabled account — credentials may be compromised

ESCALATE

Failed logon attempts — admin users only

All admin login failures originated from PAWs or DCs — expected behaviour

NOTHING SUSPICIOUS

RDP logon for service account

svc-sql1 RDP'd into PKI from 192.168.28.130 — service accounts never RDP in this environment

ESCALATE

User added/removed from local group

Unknown SID added to Administrators group — could be IT doing maintenance

CONSULT IT OPS

Admin logon not from PAW

Admin logon from a non-PAW machine — against policy but could be IT oversight

CONSULT IT OPS

SSH logins

Root SSH login detected — root should be blocked per environment policy

ESCALATE

Quick Reference — All Commands & Queries

Every KQL query and lookup value used in this module, collected in one place.



KQL — copy/paste reference

```
event.code:4625
event.code:4625 AND winlog.event_data.SubStatus:0xC0000072
event.code:4625 AND winlog.event_data.SubStatus:0xC0000072
  AND @timestamp >= "2023-03-03T00:00:00.000Z"
  AND @timestamp <= "2023-03-06T23:59:59.999Z"
event.code:4625 AND user.name: admin*
NOT user.name: *$ AND winlog.channel.keyword: Security
user.name: svc-*
event.code: 4624 AND winlog.logon.type: RemoteInteractive
(event.code: 4732 OR 4733) AND group.name: administrators
```



Windows Security Event IDs — cheat sheet

Event 4624	Successful logon	Event 4720	Account created
Event 4625	Failed logon	Event 4728	Added to global group
Event 4648	Explicit-credential logon	Event 4732	Added to local group
Event 4672	Special privileges used	Event 4733	Removed from local group
		Event 4740	Account locked out
		Event 4756	Added to universal group